

Network Scanning and Banner Grabbing

Finding live hosts, open ports and service versions — and what defenders do to make that harder.

Contents

01 Scanning fundamentals

02 Nmap and the scripting engine

03 TCP flags and scan types

04 Banner grabbing

05 Evasion techniques

06 Vulnerability scanning tools

Session plan

CLOCK	SEGMENT	MINUTES
00:00	Rules of engagement and objectives	10
00:10	Scanning fundamentals + check	10
00:20	Nmap, NSE and two walkthroughs + check	20
00:40	TCP flags and scan types + check	20
01:00	Banner grabbing and evasion + checks	20
01:20	Lab, review questions and close	10

Rules of engagement

Always obtain explicit written permission before scanning any network or system. Unauthorized scanning is illegal.

The authorization should name the exact address ranges, the hosts that are out of scope, and the time window.

Keep the scope document and your raw scan logs — they are the record of what you touched and when.

In today's lab, scan only the practice range you are given. Nothing else, including your own employer's network.

01

Scanning fundamentals

What a scan determines

Which hosts are live, and which addresses in the range are unused.

Which ports are open, and which are closed or filtered by something in the path.

What operating system a host is running, and which services and versions sit behind the open ports.

Which patches are present or missing, and whether a firewall or IDS is between you and the target.

Three kinds of scan

Network scan

Locates live computers on a network. A ping or ping sweep across a range, answering one question: who is there?

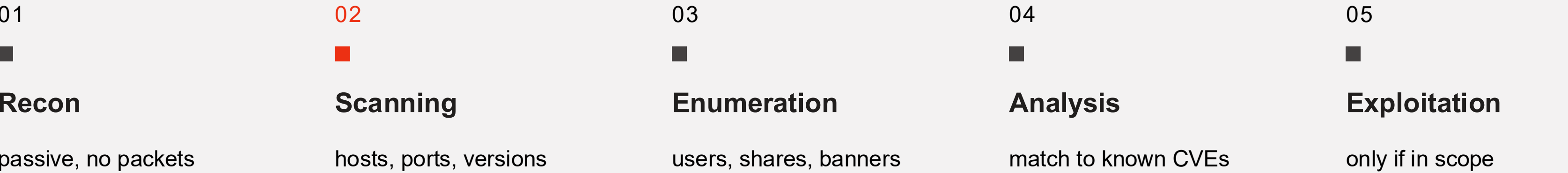
Port scan

Probes a host for open ports to identify access points and the services listening on them.

Vulnerability scan

Identifies weaknesses — outdated patches, configuration errors — by matching what it finds against a database.

Where scanning sits in the engagement



Scanning is the first phase that touches the target. Everything after it depends on how accurately you read the results — and how much noise you made getting them.

You sweep 10.10.10.0/24 and get replies from three addresses. Which kind of scan have you just run?

A A port scan

B A network scan

C A vulnerability scan

D A banner grab

You sweep 10.10.10.0/24 and get replies from three addresses. Which kind of scan have you just run?

A A port scan

B **A network scan**

C A vulnerability scan

D A banner grab

A ping sweep locates live hosts, which is the definition of a network scan. Port scanning comes next, against the three hosts that answered.

02

Nmap and the scripting engine

Core flags

FLAG	WHAT IT DOES	WHEN YOU REACH FOR IT
-sn	Host discovery only, no port scan	First pass over an unknown range
-F	Fast scan — the top 100 ports	Quick shape of a host
-p 1-1000	Scan a specific port or range	You already know what to look for
-sV	Version detection for running services	Deciding what is exploitable
-O	Operating system detection	Fingerprinting the platform
-sU	UDP scan	DNS, SNMP, TFTP — slow but revealing

Beyond the core flags

FLAG	WHAT IT DOES	COST OF USING IT
-Pn	Skip host discovery, treat every host as up	Slower, but survives ICMP filtering
-A	OS, version, script scan and traceroute together	Loud — assume it will be logged
-T0 ... -T5	Timing template, paranoid through insane	Fast is detectable; slow takes hours
--top-ports 20	The most commonly open ports first	Misses services on odd ports
-p-	All 65,535 TCP ports	Thorough and very slow
-oA base	Save output in all three formats at once	None — do this every time

Walkthrough: host discovery

```
$ nmap -sn 10.10.10.0/24
Starting Nmap 7.94 ( https://nmap.org )
Nmap scan report for 10.10.10.1
Host is up (0.0011s latency).
Nmap scan report for 10.10.10.14
Host is up (0.0026s latency).
Nmap scan report for 10.10.10.23
Host is up (0.0043s latency).
Nmap done: 256 IP addresses (3 hosts up) scanned in 2.41s
```

Read it as a shortlist, not a result: 253 addresses did not answer, which is not the same as being absent. Hosts that drop ICMP need a second need a second pass with `-Pn`.

Walkthrough: service and version detection

```
$ nmap -sV -O -p 21,22,80,443,3389 10.10.10.14
```

PORT	STATE	SERVICE	VERSION
21/tcp	open	ftp	vsftpd 2.3.4
22/tcp	open	ssh	OpenSSH 7.2p2 Ubuntu 4ubuntu2.8
80/tcp	open	http	Apache httpd 2.4.18 ((Ubuntu))
443/tcp	closed	https	
3389/tcp	filtered	ms-wbt-server	

Running: Linux 4.X

OS details: Linux 4.4 - 4.9

Three states, three meanings: `open` — something is listening. `closed` — the host answered, nothing is listening. `filtered` — no answer reached you, so a firewall is probably dropping the probe.

The Nmap Scripting Engine

```
$ ls /usr/share/nmap/scripts | wc -l
594
$ nmap --script=banner -p 21,22,80 10.10.10.14
21/tcp open  ftp
| banner: 220 (vsFTPd 2.3.4)
$ nmap --script=ftp-anon -p 21 10.10.10.14
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
```

Over 594 scripts ship in `/usr/share/nmap/scripts` , grouped into categories such as default, discovery, safe, vuln and intrusive. They cover banner grabbing, anonymous FTP, Whois lookups and much more — read a script before you run it against a client.

**You need service versions on the 100 most common ports of one host, and nothing more.
nothing more. Which command?**

A `nmap -F -sV 10.10.10.14`

B `nmap -O -p- 10.10.10.14`

C `nmap -sU -F 10.10.10.14`

D `nmap -sn 10.10.10.0/24`

You need service versions on the 100 most common ports of one host, and nothing more.
nothing more. Which command?

A **nmap -F -sV 10.10.10.14**

B `nmap -O -p- 10.10.10.14`

C `nmap -sU -F 10.10.10.14`

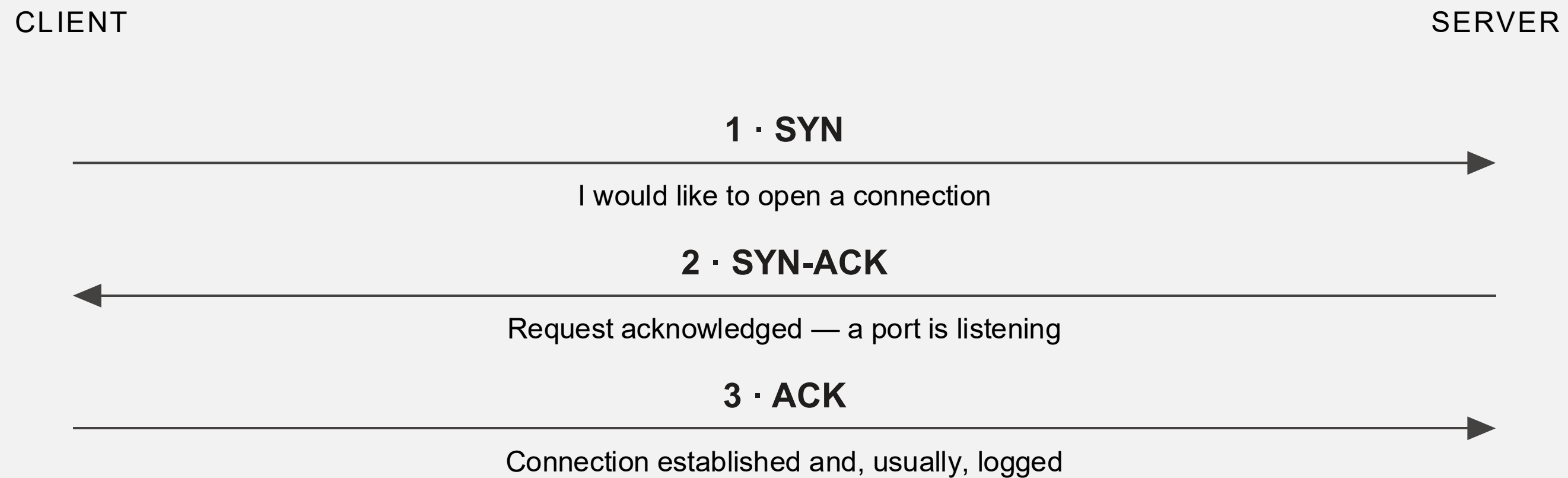
D `nmap -sn 10.10.10.0/24`

–F limits the scan to the top 100 ports and –sV adds version detection. B scans all 65,535 ports and fingerprints the OS, C scans UDP, and D never touches a port.

03

TCP flags and scan types

The three-way handshake



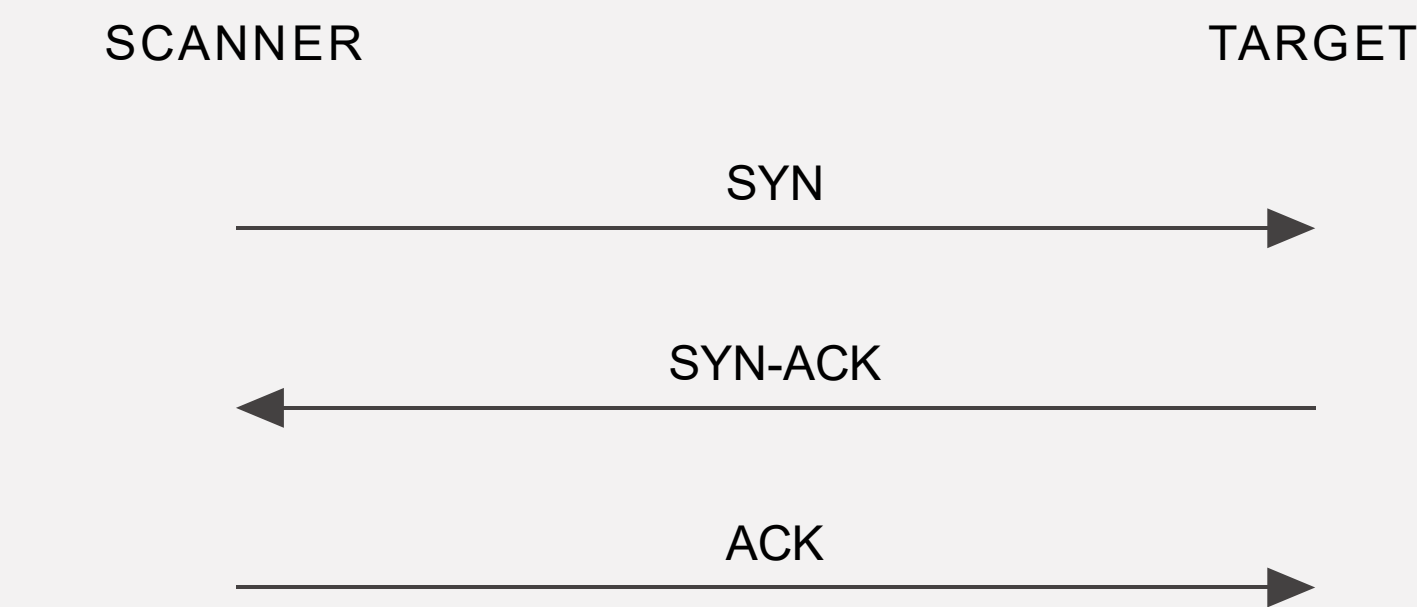
Every TCP scan type is a variation on these three packets — completing them, stopping short of them, or sending flags that sending flags that were never meant to appear together.

Flag reference

FLAG	DESCRIPTION	SEEN IN SCANNING WHEN
SYN	Start connection	Every TCP port probe opens with it
ACK	Acknowledge receipt	Probing whether a firewall keeps state
FIN	No more data	FIN scans, to slip past simple filters
RST	Reset connection	A closed port answers with it
URG	Urgent data	Part of the Christmas tree flag set
PSH	Push buffered data	Part of the Christmas tree flag set

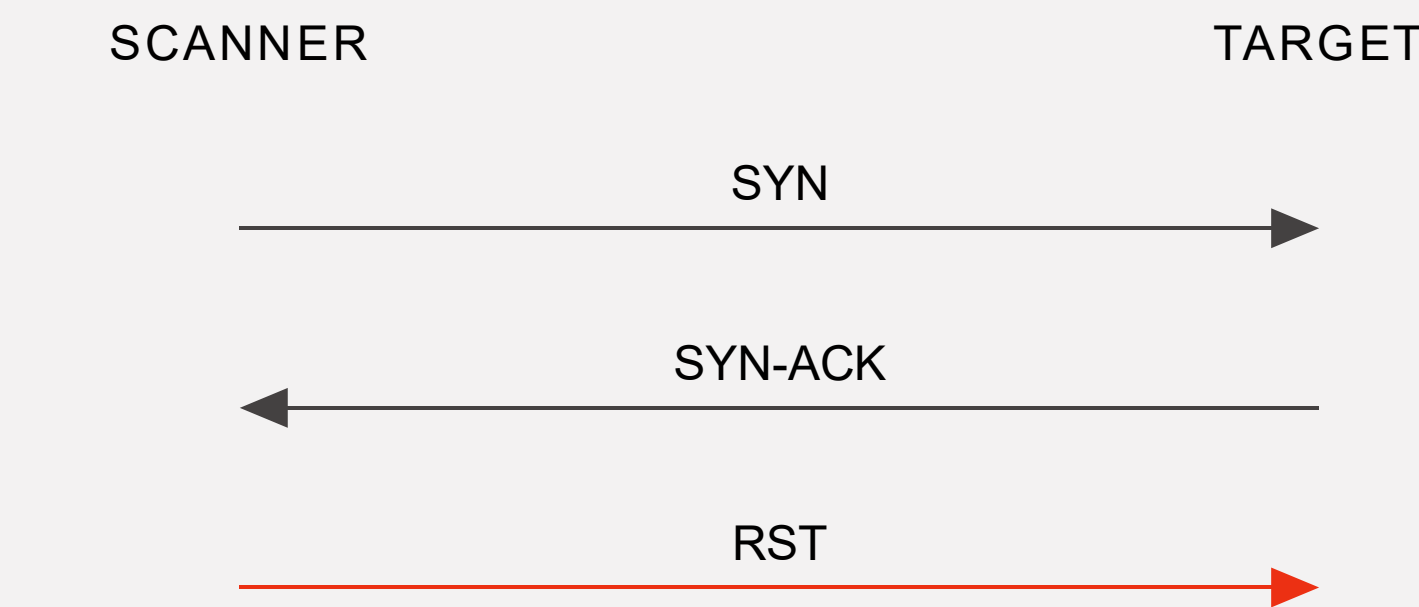
Full open and half open

Full open (-sT)



Connection completed — the application logs it

Stealth half open (-sS)



Handshake abandoned — often no application log

Scan types compared

SCAN	WHAT IT SENDS	WHY
Full open	<code>SYN → SYN-ACK → ACK</code>	Reliable, and detectable
Stealth, half open	<code>SYN → SYN-ACK → RST</code>	Stops before the final ACK
Christmas tree	<code>FIN + PSH + URG</code>	All flags set, to trigger a telling response
NULL / FIN	<code>no flags · FIN only</code>	Manipulates flags to bypass simple firewalls
Idle	<code>spoofed SYN via a third host</code>	Uses a zombie to proxy traffic and stay anonymous

The idle scan, step by step

Pick a zombie

Find an idle host whose IP identification numbers increment predictably. Note its current value.

Spoof the probe

Send the target a SYN with the zombie's source address. The target replies to the zombie, never to you.

Read the counter

Query the zombie again. A jump of two means the port was open; a jump of one means it was not.

Your address never appears in the target's logs — the zombie's does. That also makes the technique legally and ethically loaded: you are borrowing a third party's identity.

A SYN scan receives SYN-ACK from port 445 and the scanner immediately sends RST. Why the RST?

-
- A** To reset the target's firewall state table
 - B** To confirm that the port is closed
 - C** To leave the handshake incomplete, so the service is less likely to log it
 - D** To force an ICMP unreachable reply
-

A SYN scan receives SYN-ACK from port 445 and the scanner immediately sends RST. Why the RST?

-
- A** To reset the target's firewall state table
 - B** To confirm that the port is closed
 - C** **To leave the handshake incomplete, so the service is less likely to log it**
 - D** To force an ICMP unreachable reply
-

The SYN-ACK already proved the port is open. Tearing the connection down before the final ACK is what makes the scan half open — the packet capture still shows it, but many applications never see a completed session.

04

Banner grabbing

What a banner reveals

Banner grabbing retrieves welcome messages and metadata from a service to identify its software and version.

A version string is a shortlist of known vulnerabilities: `vsftpd 2.3.4` is a different conversation from `vsftpd 3.0.5`.

Active grabbing connects to the port and reads what comes back. Passive grabbing reads the traffic without sending anything.

Headers, error pages and file extensions leak the same information by accident.

Walkthrough: telnet and netcat

```
$ telnet 10.10.10.14 21
Trying 10.10.10.14... Connected to 10.10.10.14.
220 (vsFTPD 2.3.4)

$ nc 10.10.10.14 22
SSH-2.0-OpenSSH_7.2p2 Ubuntu-4ubuntu2.8

$ printf 'HEAD / HTTP/1.0\r\n\r\n' | nc 10.10.10.14 80
HTTP/1.1 200 OK
Server: Apache/2.4.18 (Ubuntu)
X-Powered-By: PHP/5.6.40
```

Three connections, three exact versions — no exploit, no credentials, nothing that looks like an attack in the logs beyond an opened socket.
opened socket.

Tools

TOOL	HOW IT WORKS	NOISE
Telnet / Netcat Netcat	Manual connection to a specific port, such as 22 or 23	One socket per grab
Nmap	<code>-sV</code> or <code>--script=banner</code>	Scan-shaped, easy to signature
Shodan.io	Search engine of banners already collected from internet-facing devices	None — you never touch the target
P0f	Passive traffic analysis, fingerprinting from packets it observes	None — sends nothing

Countermeasures

Reduce what is listening

Disable unnecessary services. A port that is not open cannot be fingerprinted, and every service you remove is one you no longer have to patch.

Reduce what it says

Obscure or remove banner information, hide file extensions, and enable custom error pages so failures do not print the stack behind them.

None of this stops a determined tester — version detection also works from behaviour. It removes the free win, which is the point.

Which measure most directly reduces what banner grabbing can learn from your servers?

-
- A** Blocking ICMP echo at the perimeter

 - B** Removing or rewriting service banners and disabling unused services

 - C** Enabling verbose error messages to speed up troubleshooting

 - D** Randomising source ports on outbound traffic

Which measure most directly reduces what banner grabbing can learn from your servers?

-
- A Blocking ICMP echo at the perimeter
 - B Removing or rewriting service banners and disabling unused services**
 - C Enabling verbose error messages to speed up troubleshooting
 - D Randomising source ports on outbound traffic
-

A slows host discovery but leaves banners intact. C makes the problem worse. D concerns your own outbound traffic, not what your services announce.

05

Evasion techniques

Getting past a firewall or IDS

ACK scanning

Send a bare ACK. Whether it is dropped or answered tells you if the firewall keeps state.

IP spoofing

Craft packets with a false source address, so the replies go somewhere else.

Packet fragmentation

Break probes into small fragments so no single packet matches a signature.

Proxying

Route through intermediary nodes for anonymity and to bypass source-based filtering.

“An ethical hacker relies on stealth for success. The longer you can remain hidden, the more successful you’ll probably be.”

— CEH Module 5

Which technique tells you whether a firewall in the path is stateful or stateless?

A Packet fragmentation

B An idle, or zombie, scan

C ACK scanning

D IP spoofing

Which technique tells you whether a firewall in the path is stateful or stateless?

A Packet fragmentation

B An idle, or zombie, scan

C **ACK scanning**

D IP spoofing

A stateful firewall has no record of a session for a bare ACK and drops it. A stateless filter passes it through and the host answers with RST.

The other three hide the scanner; they do not classify the filter.

06

Vulnerability scanning tools

The tools you will meet

TOOL	PURPOSE
Nessus	Industry standard for vulnerability assessment
OpenVAS	Testing and protocol auditing
BeyondTrust	Enterprise vulnerability management
InsightVM	Enterprise-level risk management
IP Tools	Suite of 20+ Windows utilities — SNMP, UDP and more

All of them report more findings than you can act on. The skill is triage: confirm the finding, judge the exposure, then write it up.

The defender's summary

Shrink the surface

Disable unnecessary services and close ports that nothing needs. Filter at the perimeter what should never be reachable.

Say less

Strip or rewrite banners, hide file extensions, serve custom error pages, and keep debug output off production.

Watch for the pattern

Tune the IDS for sequential and fragmented probes, and alert on scan-shaped traffic rather than single connections.

07

Lab and review

Lab: scan the practice range

```
Target range  10.10.10.0/24  (nothing outside it)
1  Find the live hosts.
2  Fast-scan one host, then version-scan the ports you found.
3  Grab one banner by hand with telnet or nc.
4  Note one port that is filtered rather than closed.
```

Post your version string for the FTP or SSH service in the chat when you have it. We will compare results and talk through anything that came back filtered.

Review questions, 1 and 2

1 · Which flags does a Christmas tree scan set?

- A · SYN only
- B · FIN, PSH and URG
- C · No flags at all

2 · Which tool fingerprints an OS without sending a packet? packet?

- A · Nessus
- B · P0f
- C · Netcat

Review questions, 3 and 4

3 · What does a filtered port state usually indicate?

- A · No service is listening
- B · Something is dropping the probe
- C · The host is down

4 · Which scan proxies the probe through a third host?

- A · Idle scan
- B · ACK scan
- C · UDP scan

Answer key

Q	ANSWER	WHY
1	B	FIN, PSH and URG together — flags that never appear in a normal session
2	B	P0f analyses traffic passively; the other two must connect
3	B	No reply reached the scanner, so a firewall is probably dropping it
4	A	The idle scan reads a zombie’s IP ID counter instead of talking to the target directly

Five points to carry out of the session

Written authorization first, every time, naming ranges and time windows.

Scan in stages: hosts, then ports, then versions. Each stage narrows the next.

Read the port state, not just the port: open, closed and filtered mean three different things.

A version string is the shortest path from a scan to a vulnerability, in either direction.

Stealth is a choice with a cost — slower scans, thinner data, and it is never invisible.

Questions

Next session: enumeration — turning the open ports from today's lab into users, shares and shares of the attack surface.

Slides and lab notes will be shared after the session